



CYBLACK x **FortisAid**

FortisAid Governance, Risk & Compliance (GRC)

Policy Set, Training and Compliance Framework – CyBlack Team 2

Table of Contents

Table of Contents.....	i
List of Figures.....	ii
List of Tables.....	iii
Executive Summary.....	1
1.0 Introduction.....	2
2.0 Overview of FortisAid Context: Addressing Key Risks and Threats.....	2
3.0 FortisAid Governance Structure.....	3
4.0 Domain, Sub-domain & Control Mapping Table.....	4
5.0 FortisAid Policies.....	7
5.1 Information Security Policy.....	7
5.11 Document Control Page.....	7
5.12 Purpose and Scope.....	8
5.13 Policy Statements / Requirements.....	8
5.14 Review and Revision.....	9
5.2 Privileged Account Policy.....	10
5.21 Document Control Page.....	10
5.22 Purpose and Scope.....	11
5.23 Policy Statements / Requirements.....	11
5.24 Review and Revision.....	12
5.3 Third-Party and Supplier Security Policy.....	13
5.31 Document Control Page.....	13
5.32 Purpose and Scope.....	14
5.33 Policy Statements / Requirements.....	14
5.34 Review and Revision.....	15
5.4 FortisAid Information Security Incident Management Policy.....	16
5.41 Document Control Page.....	16
5.42 Purpose and Scope.....	17
5.43 Policy Statements / Requirements.....	17
5.44 Review and Revision.....	18
5.5 Information Classification Policy.....	19
5.51 Document Control Page.....	19
5.52 Purpose and Scope.....	20
5.53 Policy Statements / Requirements.....	20
5.54 Review and Revision.....	21
5.6 Data Protection And Privacy Policy.....	22
5.61 Document Control page.....	22
5.62 Purpose and Scope.....	23

5.63 Policy Statements.....	23
5.64 Review and Maintenance.....	24
5.7 Identity Management and Access Control Policy.....	25
5.71 Document Control Page.....	25
5.72 Purpose and Scope.....	26
5.73 Policy Statements / Requirements.....	26
5.74 Review and Revision.....	27
5.8 Endpoint and Clinical Device Security Policy.....	28
5.81 Document Control Page.....	28
5.82 Purpose and Scope.....	29
5.83 Policy Statements.....	29
5.84 Review & Training Cycle.....	30
5.9 Clear Desk and Clear Screen Policy.....	31
5.91 Document Control Page.....	31
5.92 Purpose and Scope.....	32
5.93 Policy Statements / Requirements.....	32
5.94 Review and Revision.....	33
6.0 AI Governance Policy.....	34
6.11 Document Control Page.....	34
6.12 Purpose and Scope.....	35
6.13 Policy Statements / Requirements.....	35
6.14 Review and Revision.....	36
FortisAid Policy Compliance Framework.....	37
Uploading and Signing Policies on Wizer.....	38
Recommendations for successful implementation of the Framework.....	43
Conclusion.....	45
References.....	46

List of Figures

FortisAid Governance Structure.....	2
FortisAid Policy Compliance Framework.....	35
FortisAid Policy Compliance Framework Continuation.....	35
Wizer Learner Dashboard	43
Signature setup for the COO	44
Signature of COO	44
FortisAid Employees Tracking Dashboard.....	45
A signed policy.....	46

List of Tables

Domain, Sub-domain & Control Mapping.....	2
---	---

Executive Summary

FortisAid operates within a highly regulated healthcare environment where the confidentiality, integrity, and availability of Patient Health Information (PHI), Electronic Health Records (EHR), and clinical systems are critical to patient safety and Organizational trust. A recent governance review identified the absence of formally documented information security policies aligned to ISO/IEC 27002:2022. To address this gap, ten comprehensive security policies were developed to establish a structured and risk-based Information Security Management framework.

The policies developed include:

- Information Security Policy
- Privileged Account Policy
- Third-Party and Supplier Security Policy
- Information Classification Policy
- Incident Management Policy
- Data Protection and Privacy Policy
- Endpoint and Clinical Device Security Policy
- Identity Management and Access Control Policy
- Clear Desk and Clear Screen Policy
- Artificial Intelligence (AI) Security and Governance Policy

Each policy was developed based on FortisAid's operational context as a healthcare technology provider, addressing key risks such as ransomware attacks, insider threats, unauthorised access to PHI, supply chain vulnerabilities, misuse of privileged accounts, and emerging AI-related risks.

The policies are formally structured with defined document control, assigned authors and owners, role-based governance responsibilities, annual review cycles, and executive approval. Each policy is mapped to relevant domains and controls within ISO/IEC 27002:2022 and incorporates applicable regulatory requirements including healthcare data protection obligations.

A Policy Compliance Framework was also developed to ensure ongoing monitoring, accountability, and continuous improvement. The framework defines measurable activities, review frequencies, responsible roles, and evidence requirements to support audit readiness and regulatory compliance.

Collectively, these policies strengthen FortisAid's governance, risk management, and compliance posture, enabling the organisation to safeguard sensitive healthcare information, as well as maintain trust with patients, partners, and regulators.

1.0 Introduction

This report presents the development of ten security policies for FortisAid Health Technologies in alignment with ISO/IEC 27002:2022. The policies were developed to address identified governance gaps, mitigate healthcare-specific risks, and ensure regulatory compliance. The report outlines policy governance structure, ISO mapping, compliance monitoring mechanisms, and recommendations for effective implementation.

2.0 Overview of FortisAid Context: Addressing Key Risks and Threats

FortisAid operates in a highly sensitive healthcare environment, where the confidentiality, integrity, and availability of patient data and clinical services are very important. Given the nature of the healthcare industry, FortisAid faces a range of significant information security risks that must be addressed proactively to ensure patient safety, regulatory compliance, and organizational trust.

One of the most pressing threats is the risk of ransomware attacks targeting hospital and healthcare infrastructure, which can result in the disruption of clinical services and the compromise of patient safety. In addition to external attacks, insider threats, including accidental data leakage and unauthorized access, pose a significant risk to FortisAid's operations. These threats, combined with issues such as cloud security misconfigurations and physical breaches like the theft of devices, highlight the need for very secure access controls and strict security measures.

This is why these policies have been designed to help maintain the confidentiality, integrity, and availability of patient data, as well as the security standing posture of FortisAid. For example FortisAid's Information Security Policy has been developed to address these threats by ensuring that all patient information is securely managed, and that sensitive data is protected from unauthorized access or accidental exposure. Policies such as Privileged Account Management ensure that administrator credentials are safeguarded from phishing attacks and insider misuse, while Identity Management and Access Control policies limit access to sensitive healthcare data through role-based permissions and continuous monitoring.

The Endpoint and Clinical Device Security Policy focuses on mitigating risks related to unpatched clinical systems and compromised devices containing Protected Health Information (PHI). It aims to prevent malware attacks and unauthorized access to critical medical equipment, thereby ensuring that clinical operations run smoothly and patient safety is not compromised.

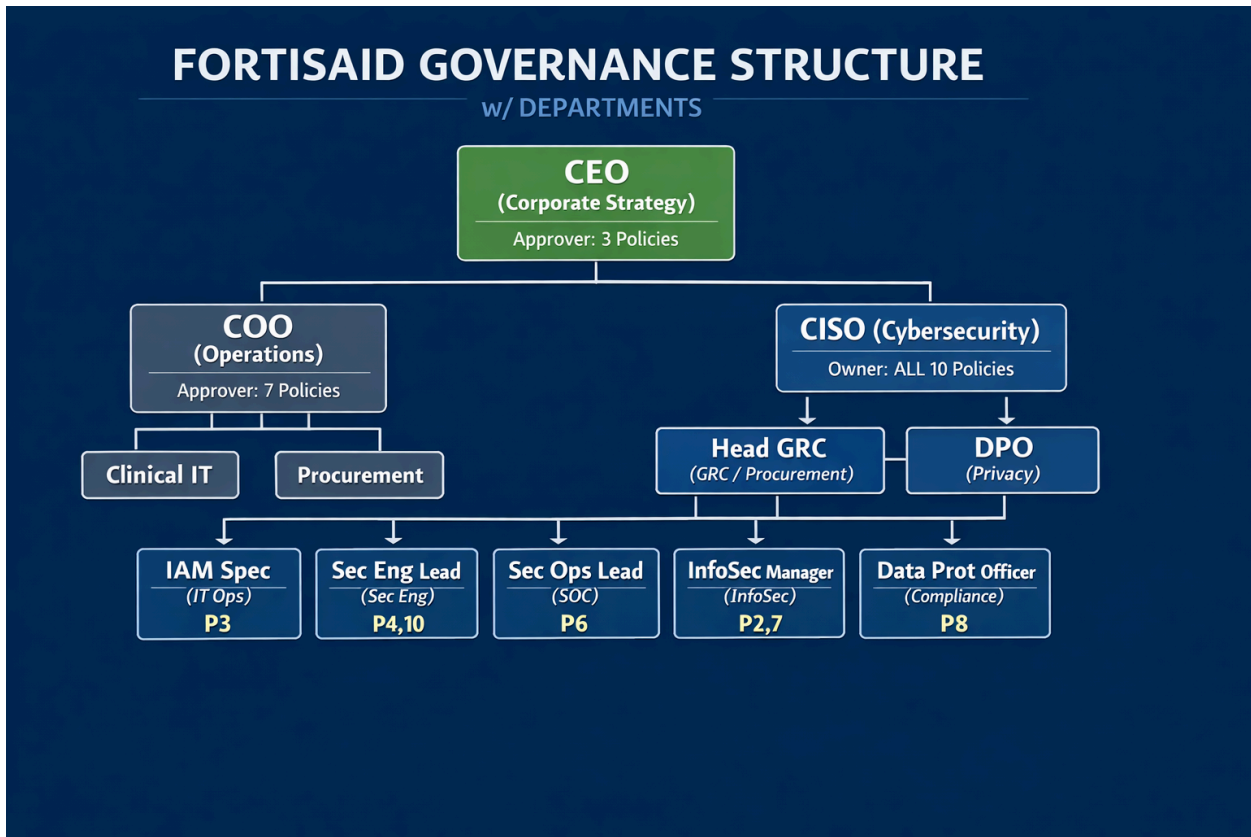
Furthermore, policies like the Clear Desk and Clear Screen Policy protect against physical breaches, such as unauthorized viewing of patient records or the theft of printed medical documents, in high-traffic or shared spaces. This policy reduces the likelihood of accidental exposure of sensitive data in clinical or reception areas, which could lead to regulatory penalties and reputational damage.

The overall goal of these policies is to mitigate the risks and threats that FortisAid faces, ensuring that sensitive patient data is protected, clinical services remain uninterrupted, and compliance with

regulatory requirements such as **UK GDPR** and **HIPAA** is consistently maintained. Through these security policies, FortisAid strengthens its ability to prevent, detect, and respond to security incidents while maintaining the trust of patients, regulatory bodies, and stakeholders.

3.0 FortisAid Governance Structure

The diagram below outlines FortisAid Governance Structure, including the roles responsible for the development, approval, and ownership of the security policies.



A diagram of FortisAid Governance Structure

From the diagram above,

- ❖ CEO (Corporate Strategy) is the approver for three policies, ensuring alignment with corporate strategy.

- ❖ COO (Operations) approves seven policies, covering operational areas such as Clinical IT and Procurement.
- ❖ The CISO (Cybersecurity) is the central policy owner, overseeing all ten policies, and ensuring alignment with FortisAid's security posture.
- ❖ Head of GRC (Governance, Risk, Compliance) and DPO (Data Protection Officer) oversee specialized policies related to compliance and privacy.
- ❖ Individual policy authors are allocated based on their functional expertise, with each policy reviewed by an appropriate manager from the security and compliance teams.

This governance structure ensures clear accountability and segregation of duties across all security policies within FortisAid.

4.0 Domain, Sub-domain & Control Mapping Table

The table shows the mapping of each policy to its respective ISO 27002 domain, sub-domain, and control numbers. Each policy has been developed to address specific domains of information security, ensuring alignment with best practices and industry standards.

Policy Name	Domain	Sub-Domain	Control
Information Security Policy	Organizational Controls, Technological Controls, Physical Security, System and Application control	Information Security Policies, Asset Management	5.1, 5.9, 5.15, 7.1, 8.1, 8.2
Privileged Account Policy	Organizational Controls / Technological Controls	Access Control / Identity & Privileged Access Management	5.15, 5.16, 5.18, 8.2, 8.15
Third-Party and Supplier Security Policy	Organizational Controls	Supplier relationships	5.19

Information Classification Policy	Organizational Controls	Classification of information, Labelling of information, Privacy and protection of PII	5.12, 5.13, 5.34
Incident Management Policy	Organizational Controls	Information security incident management planning and preparation, Assessment and decision on information security events, Response to information security incidents, Learning from information security incidents, Collection of evidence	5.24, 5.25, 5.26, 5.27, 5.28
Data Protection and Privacy Policy	Organizational / Technological / People / Physical Controls	Privacy and protection of PII, Data Masking, Data Leakage protection	5.14, 5.33, 5.34, 6.3, 7.2, 7.10, 8.11, 8.12
Endpoint and Clinical Device Security Policy	Technological Controls	User Endpoint Devices, Protection Against Malware, Information Deletion	8.1, 8.7, 8.10
Identity Management and Access Control Policy	Organizational Controls	Access Control, Identity Management	5.15, 5.16
Clear Desk and Clear Screen Policy	Physical Controls	Clear desk and clear screen, Information Classification, Physical Security Monitoring	7.7, 5.12, 7.4

AI Governance Policy	Organizational Controls	Threat Intelligence	5.7
----------------------	-------------------------	---------------------	-----

Table 1: Domain, Sub-domain & Control Mapping

From the table above, the policies cover a broad range of security areas, from information security policy, to clear desk and screen policy. By aligning each policy with the appropriate ISO controls, FortisAid ensures a structured approach to managing information security risks, as well as maintaining a strong security posture across the organization.

5.0 FortisAid Policies



5.1 Information Security Policy

5.11 Document Control Page

Field	Details
Policy Title	Information Security Policy
Policy Number	FTAID-POL-001
Author	Head of Governance Risk and Compliance
Policy Owner	Chief Information Security Officer
Reviewer	Data Protection Officer
Approver	Chief Executive Officer
Version	1.0
Effective Date	19 February 2026
Current Review Date	19 February 2026
Next Review Date	19 February 2027
ISO 27002:2022 Domain	Organizational Controls, Technological Controls, Physical Security, System and Application control
ISO 27002:2022 Sub-domain	Information Security Policies, Asset Management
ISO 27002:2022 Control	5.1, 5.9, 5.15, 7.1, 8.1, 8.2
Related Policies	Confidentiality and Data Protection Policy, Access Control Policy, Records Management Policy, Incident Reporting Policy, Network Security Policy
Approval Status	Approved

5.12 Purpose and Scope

Purpose

The purpose of this policy is to establish a comprehensive framework for the protection of FortisAid Health Technologies' information assets, while ensuring that the health-related data remains confidential, maintains integrity, and is available. This in compliance with healthcare regulatory and security standards, with the aim of mitigating threats such as unauthorized access.

Scope

This policy applies to:

- i. All FortisAid employees, contractors, consultants, volunteers, and third-party users working on behalf of FortisAid.
- ii. All information assets, including patient data, clinical systems, business systems, cloud platforms, networks, endpoints such as laptops and mobile devices, and medical applications.
- iii. All physical, digital, and cloud-based environments operated or managed by FortisAid.

5.13 Policy Statements / Requirements

1. Information Asset Management

Any information assets including databases and hardcopy records should be documented in an Information Asset Register (IAR) and allocated to an Information Asset Owner (IAO) who oversees risk assessment and business continuity. The assets should be categorized by the sensitivity e.g. confidential patient data and be secured both to satisfy the operational needs of NHP, UK GDPR of personal/special category data, and ISO of inventory and risk management. Periodic audits of assets will be performed to ensure that the DSPT standards are met, such as anonymizing or pseudonymizing the assets when necessary to lower the chances of identification.

2. Access Controls and Security

The access to information systems will be based on the least-privilege concept and IAOs-authorized role based access. Patient data systems should have multi-factor authentication (MFA) and smart cards. Unique and complex passwords that are not shared should be deployed; generic accounts must not be utilized unless the emergency case is approved. Badges, codes or escorted access will be used to restrict physical access to security which are consistent with the ISO physical security perimeters. The remote working process

must be conducted with encrypted gadgets and connections; the storage of confidential data must be conducted exclusively with the agreement and the valid utilization of personal tools.

3. Data Protection and Transfers

Encryption of the special category data and personal data, both at rest and in transit, should be approved by SIRO, and the transfer of non-routine bulk data greater than 50 records should be encrypted. Transfers out of UK/EEA ought to be complying with the UK GDPR protection; fax transfer of confidential information is not allowed. Changes or new systems should be subject to Data Protection Impact Assessment (DPIAs) to ensure the compliance with Digital Technology Assessment Criteria (DTAC).

4. Incident Management and Business Continuity

All security incidents are to be notified within 24 hours under the Incident Reporting Policy of NHP and all the serious breaches notified to the ICO within 72 hours. To ensure business continuity plans will be taken on the critical assets to make them available yearly and linked to the Risk Management Framework of NHP. Forensic preparedness will be made through audit trails and preservation of evidence as well as preparations of investigations.

5. Physical and Environmental Security

Storage spaces for the information must be secured (e.g., locked compartments, fire precautions). Equipment disposal to be done should also include secured data destruction; re-use should be evaluated. There should be a clear desk policy and safe disposal of waste to prevent unauthorized entry.

5.14 Review and Revision

This policy will be reviewed annually or in case of security incidents or data breaches, changes to the country's legislation, i.e., GDPR updates or FortisAid guidance, and organizational changes affecting information assets.

Next scheduled review: 21 February 2027.

5.2 Privileged Account Policy

5.21 Document Control Page

Field	Details
Policy Title	Privileged Account Policy
Policy Number	FTAID-POL-002
Author	Security Engineering Lead
Policy Owner	Chief Information Security Officer
Reviewer	Security Operations Lead
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls / Technological Controls
ISO 27002:2022 Sub-domain	Access Control / Identity & Privileged Access Management
ISO 27002:2022 Control	5.15, 5.16, 5.18, 8.2, 8.15
Related Policies	Information Security Policy, Access Control Policy, Logging & Monitoring Policy
Approval Status	Approved

5.22 Purpose and Scope

Purpose

This policy establishes controls for the creation, approval, monitoring, and secure use of privileged accounts to protect FortisAid's clinical systems, patient data, and cloud infrastructure from misuse or compromise.

Scope

This policy applies to:

- All FortisAid employees, clinicians, contractors, vendors, and third parties
- All systems, including EHR platforms, remote patient monitoring (RPM), cloud services, databases, and network infrastructure
- All accounts with administrative, root, system-level, or elevated privileges

FortisAid Context

FortisAid delivers digital healthcare services using cloud-hosted electronic health records, remote patient monitoring platforms, and clinical analytics systems that process and store sensitive patient health information.

5.23 Policy Statements / Requirements

1. Privileged Account Assignment
 - a. Privileged access shall be granted only when necessary, in accordance with least-privilege principles.
 - b. All privileged accounts must be individually assigned; shared administrative accounts are prohibited unless technically unavoidable and formally approved.
 - c. Requests for privileged access must include:
 - Business justification
 - System owner approval
 - Information Security approval
2. Secure Use of Privileged Accounts
 - a. Privileged accounts must be used only for administrative tasks, not for routine work such as email or browsing.
 - b. Multi-factor authentication (MFA) is mandatory for all privileged access to FortisAid systems.
 - c. Privileged sessions must be:
 - Logged
 - Time-limited where possible
 - Conducted via secure management workstations or privileged access management (PAM) tools

- d. Default vendor or system administrator passwords must be changed immediately upon deployment.
- 3. Monitoring, Review, and Removal
 - a. All privileged account activity shall be logged and monitored for suspicious behaviour.
 - b. The IAM or Security team shall conduct quarterly reviews of privileged accounts to verify:
 - Continued business need
 - Correct privilege level
 - Account ownership
 - c. Privileged access must be revoked immediately when:
 - A staff member changes role
 - A contractor engagement ends
 - An account is suspected of being compromised
 - d. Dormant privileged accounts inactive for 30 days must be automatically disabled unless justified.

5.24 Review and Revision

This policy will be reviewed annually or following:

- Security incidents involving privileged accounts
- Changes to UK healthcare security requirements
- Major infrastructure or cloud platform changes

Next scheduled review: 18 February 2027.

5.3 Third-Party and Supplier Security Policy

5.31 Document Control Page

Field	Details
Policy Title	Third-Party and Supplier Security Policy
Policy Number	FTAID-POL-003
Author	Head of Procurement and Vendor Management
Policy Owner	Chief Information Security Officer
Reviewer	Information Security Manager
Approver	Chief Executive Officer
Version	1.0
Effective Date	20 February 2026
Current Review Date	20 February 2026
Next Review Date	20 February 2027
ISO 27002:2022 Domain	Organisational Controls
ISO 27002:2022 Sub-domain	Supplier relationships
ISO 27002:2022 Control	5.19
Related Policies	Data Protection Policy, Cloud Security, Privileged Account Policy
Approval Status	Approved

5.32 Purpose and Scope

Purpose:

To manage security risks from third parties accessing FortisAid systems, cloud platforms, or PHI during EHR integration, RPM device supply, and analytics services.

Scope:

All suppliers, vendors, contractors providing cloud services, RPM devices, EHR integrations, lab systems, or analytics platforms.

FortisAid Context:

Secures cloud vendors (AWS/Azure), RPM device manufacturers, EHR integrators handling sensitive patient data.

5.33 Policy Statements / Requirements

1. Vendor Risk Assessment and Classification (5.19)
 - Classify vendors: High Risk (PHI access: EHR, RPM, labs), Medium (cloud infra), Low (non-data).
 - Pre-contract assessment mandatory: ISO 27001/SOC2 certification, security questionnaire, penetration test review.
 - High-risk vendors require an annual on-site/remote audit by the Information Security Manager.
2. Contractual Security Requirements (5.20)
 - All contracts include Business Associate Agreements (BAAs) with: 24hr breach notification, right to audit, £5M liability minimum.
 - Cloud vendors (5.23): UK/EEA data residency, customer-managed encryption keys, SOC2 Type II.
 - RPM device vendors: Secure boot, firmware signing, vulnerability disclosure process.
3. Access and Technical Controls
 - Vendor access via just-in-time privileged accounts (8.2), MFA mandatory, session recording.
 - Vendor endpoints comply with 8.1 (encryption, EDR, patching); no direct PHI export.
 - API integrations use OAuth2/JWT with scoped tokens, rate limiting.
4. Monitoring and Performance Management (5.22)
 - Vendor security scorecards updated monthly: patch compliance, incident history, cert validity.
 - Quarterly business reviews for high-risk vendors covering security KPIs.

- 60-day advance notice required for vendor changes (M&A, subcontractors, data center moves).

5.34 Review and Revision

- This policy will be reviewed annually or following significant incidents (vendor breaches, supply chain attacks, regulatory changes).
- Next scheduled review: 23 February 2027.
- Triggers for unscheduled review: Major vendor incidents, new GDPR processor requirements, cloud security framework updates.

5.4 Information Security Incident Management Policy

5.41 Document Control Page

Field	Details
Policy Title	Information Security Incident Management Policy
Policy Number	FTAID-POL-004
Author	Security Operations Lead
Policy Owner	Chief Information Security Officer
Reviewer	Clinical Systems Director
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls
ISO 27002:2022 Sub-domain	Information security incident management planning and preparation, Assessment and decision on information security events, Response to information security incidents, Learning from information security incidents, Collection of evidence
ISO 27002:2022 Control	5.24, 5.25, 5.26, 5.27, 5.28
Related Policies	Information Security Policy, Access Control Policy, Logging & Monitoring Policy
Approval Status	Approved

5.42 Purpose and Scope

Purpose

This policy establishes a structured, consistent, and effective approach to planning for, detecting, assessing, prioritizing, responding to, learning from, reporting, and documenting information security incidents. It ensures quick containment, appropriate reporting, and continuous improvement to reduce future risks

Scope

This information security incident management policy applies to all Fortisaid employees, contractors, temporary staff, volunteers, third parties, and systems processing health and care information. It covers all information security events/incidents affecting the confidentiality, integrity, or availability of information assets, including cyber incidents, data breaches, unauthorised access, malware, ransomware, and physical security events impacting information.

5.43 Policy Statements / Requirements

1. Incident Detection and Reporting

- All staff must promptly report suspected or confirmed security incidents to the IT Service Desk.
- Security systems must continuously monitor for abnormal activity.
- Incident reports must include time, type, and potential impact.

2. Incident Response and Escalation

- The Incident Response Team must assess and prioritize incidents based on impact and urgency.
- Escalation must follow predefined communication channels.
- Critical healthcare system incidents must be addressed immediately to ensure patient safety.

3. Post-Incident Review and Improvement

- Lessons learned must be documented and reviewed within seven days of incident closure.

- Evidence must be collected and preserved according to legal requirements.
- Findings must inform training and updates to prevent recurrence.

5.44 Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- Next scheduled review: 18 February 2027.

5.5 Information Classification Policy

5.51 Document Control Page

Field	Details
Policy Title	Information Classification Policy
Policy Number	FTAID-POL-005
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Clinical Systems Director
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls
ISO 27002:2022 Sub-domain	Classification of information; Labelling of information; Privacy and protection of PII
ISO 27002:2022 Control	5.12, 5.13, 5.34
Related Policies	Data Protection and Privacy Policy, Access Control Policy, Acceptable Use Policy
Approval Status	Approved

5.52 Purpose and Scope

Purpose

To define how FortisAid classifies, labels, and handles information so that patient health information (PHI), personally identifiable information (PII), and clinical/operational data receive protection proportional to risk, supporting safe care delivery and regulatory compliance.

Scope

This policy applies to all FortisAid employees, clinicians, contractors, interns, agency staff, and third parties who create, access, store, process, transmit, or dispose of FortisAid information in any form (digital, paper, verbal, image/audio, backups, and logs), across all systems including cloud services, endpoints, and clinical platforms.

FortisAid Context

FortisAid is a UK based healthcare technology organisation delivering secure digital health services, remote patient monitoring, and clinical data analytics solutions to healthcare providers and private medical partners. The organisation processes large volumes of sensitive patient information including electronic health records, diagnostic images, laboratory results, and clinician documentation. FortisAid also manages employee records, supplier contracts, and operational system data. Operations are primarily cloud hosted, with secure remote access provided to clinicians, administrative staff, and authorised partners. Information security is critical to patient safety, regulatory compliance, operational continuity, and organisational trust.

5.53 Policy Statements / Requirements

1. Classification Scheme and Ownership

- FortisAid will maintain a standard classification scheme: Public, Internal, Confidential, and Highly Sensitive (PHI/PII).
- Information Asset Owners must assign a classification at creation (or at first receipt) and review classification at least annually or on material change.

2. Labelling and Handling Requirements

- All confidential and Highly Sensitive information must be clearly labelled in documents and datasets; digital assets must include metadata labels where supported.
- Highly Sensitive (PHI/PII) must not be shared via personal email, consumer messaging apps, or unmanaged file-sharing services; approved secure channels must be used.

3. Storage, Transmission, and Disposal Controls

- Confidential and Highly Sensitive information must be stored only in FortisAid-approved systems with access controls; local storage requires device encryption and approval.
- Highly Sensitive information must be encrypted in transit and at rest using approved cryptographic mechanisms; backups must inherit the same classification

5.54 Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- Next scheduled review: 18 February 2027.

5.6 Data Protection And Privacy Policy

5.61 Document Control page

Field	Details
Policy Title	Data Protection and Privacy Policy
Policy Number	FTAID-POL-006
Author	Data Protection Officer
Policy Owner	Chief Information Security Officer
Reviewer	Head of Governance Risk and Compliance
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational / Technological / People / Physical Controls
ISO 27002:2022 Sub-domain	Privacy and protection of PII, Data Masking, Data Leakage ProtectionI
ISO 27002:2022 Control	5.14, 5.33, 5.34, 6.3, 7.2, 7.10, 8.11, 8.12
Related Policies	Information Security Policy, Third-Party and Privacy Policy
Approval Status	Approved

5.62 Purpose and Scope

Purpose

FortisAid is a healthcare organization that processes patient and staff personal data, including special category health data. This policy sets mandatory requirements to ensure lawful processing, privacy protection, and secure handling of personal data across all operations, systems, and suppliers.

Scope

This policy applies to:

- All FortisAid personnel (employees, clinicians, agency staff, interns, contractors)
- All third parties processing personal data on FortisAid's behalf
- All processing environments: EHR/clinical systems, patient portals, emails, cloud services, endpoints, medical devices, backups, paper records, archives
- All personal data relating to patients, carers/relatives (where applicable), staff, job applicants, vendors, and visitors

5.63 Policy Statements

1. Privacy and Protection of Health Data

- FortisAid shall process patient data lawfully, fairly, and transparently.
- Special category health data shall only be processed under a documented lawful condition.
- Patient data shall be limited to what is necessary for defined clinical, legal, or operational purposes.
- FortisAid shall maintain documented accountability evidence demonstrating compliance.

2. Secure Information Transfer

- Transfers of health data shall be protected against unauthorised access, interception, alteration, or loss.
- High-risk data shall not be transmitted through insecure channels.
- Recipient identity shall be verified before transmitting health data.

- Transfers to external parties shall be governed by documented agreements defining privacy and security obligations.

3. Protection and Integrity of Records

- FortisAid shall protect records from unauthorised access, alteration, destruction, or loss.
- Records shall be stored in secure environments appropriate to their classification level.
- Clinical and legal records shall be maintained in a manner that preserves their integrity and availability.

4. Data Masking and Pseudonymisation

- Patient data shall be masked, anonymised, or pseudonymised.
- Live patient data shall not be used for testing or development unless formally authorised.
- Re-identification capability shall be restricted and controlled.

5. Data Leakage Prevention and Monitoring

- FortisAid shall implement safeguards to prevent unauthorised disclosure of patient data.
- Systems shall restrict unauthorised copying, exporting, or bulk extraction of sensitive data where feasible.
- Monitoring mechanisms shall detect potential data exfiltration attempts.
- Suspected data leakage events shall be investigated promptly.

5.64 Review and Maintenance

This policy shall be reviewed:

- Annually, and After a significant incident/breach,
- After major regulatory or business change and after a major system or processing change.

5.7 Identity Management and Access Control Policy



5.71 Document Control Page

Field	Details
Policy Title	Identity Management and Access Control Policy
Policy Number	FTAID- POL-007
Author	Security Operations Lead
Policy Owner	Chief Information Security Officer
Reviewer	Clinical Systems Director
Approver	Chief Executive Officer (CEO)
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organizational Controls
ISO 27002:2022 Sub-domain	Access Control, Identity Management
ISO 27002:2022 Control Reference(s)	5.15, 5.16
Related Policies	Classification of Information Policy, Access Rights Policy, Privileged Access Rights Policy
Approval Status	Approved

5.72 Purpose and Scope

Purpose

This policy ensures that FortisAid controls access to its information systems, applications, and physical assets by appropriately managing identity and access rights to safeguard the confidentiality, integrity, and availability of sensitive healthcare data.

Scope

This policy applies to all employees, contractors, clinicians, and vendors who require access to FortisAid's IT systems, applications, and data, including Electronic Health Records (EHR), patient health information (PHI), and cloud systems.

FortisAid Context

Given FortisAid's commitment to providing safe and high-quality healthcare services, this policy covers how patient data, including sensitive health records, is accessed and managed securely across FortisAid's internal systems, including EHR systems, cloud storage, and remote access to clinical data.

5.73 Policy Statements / Requirements

1. Access Control Rules

- Access to FortisAid's systems and assets shall be restricted in accordance with the Need-to-Know and Need-to-Use principles.
- Access to healthcare data will be role-based (RBAC), ensuring that individuals are granted the minimum level of access necessary to perform their job functions.
- Access control rules shall be formally defined, approved, and periodically reviewed to ensure alignment with FortisAid's information classification, regulatory obligations, and patient safety requirements.

2. Identity Management

- Each user identity must be unique and associated with a specific individual or entity.
- Identities must be disabled or removed when no longer required (e.g., upon termination or role change).
- Third-party identities (e.g., contractors) must be verified for appropriate trust level before granting access.

5.74 Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- Next scheduled review: 18 February 2027.

5.8 Endpoint and Clinical Device Security Policy

5.81 Document Control Page

Field	Details
Policy Title	Endpoint and Clinical Device Security Policy
Policy Number	FTAID-POL-008
Author	Security Engineering Lead
Policy Owner	Chief Information Security Officer
Reviewer	IAM Specialist
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Technological Controls
ISO 27002:2022 Sub-domain	User Endpoint Devices, Protection Against Malware, Information Deletion
ISO 27002:2022 Control	8.1, 8.7, 8.10
Related Policies	Identity Management and Access Control Policy, Incident Management Policy, Information Classification Policy
Approval Status	Approved

5.82 Purpose and Scope

Purpose

This policy establishes security requirements for endpoint and clinical devices at FortisAid to ensure the confidentiality, integrity, and availability of patient and organizational information.

It ensures compliance with healthcare regulatory obligations, industry best practices, and ISO/IEC 27002:2022 control requirements.

Scope

This policy applies to:

- All endpoint devices, clinical systems, servers, storage media, and cloud-hosted workloads, within FortisAid.
- All employees, contractors, and third-party users with access to these systems used

FortisAid Context

As a healthcare organization handling sensitive clinical data, FortisAid relies on secure endpoints and medical technologies, including Electronic Health Record (EHR) systems, cloud-integrated diagnostic devices, and remote monitoring tools. This policy ensures these systems are protected against malware, ransomware, unauthorized access, and operational disruptions that could impact patient care

5.83 Policy Statements

1. User Endpoint Devices

- All endpoint devices must be configured according to approved secure baseline standards before deployment.
- Only authorized and managed devices may connect to FortisAid's network or cloud resources.
- Administrative privileges on endpoints must be restricted and granted based on least privilege principles.
- Endpoint devices must have disk encryption enabled to protect data at rest.
- Automatic screen lock must activate after a defined period of inactivity.

- Lost or stolen devices must be reported immediately and remotely disabled or wiped where possible.

2. Protection Against Malware

- Approved anti-malware and Endpoint Detection & Response (EDR) solutions must be installed and active on all systems.
- Malware signatures and detection engines must update automatically.
- Real-time protection must not be disabled without formal authorization.
- Email attachments, removable media, and downloaded files must be automatically scanned.
- Security alerts generated by anti-malware systems must be investigated promptly.
- Users must not install unauthorized software.

3. Information Deletion

- Sensitive data must be securely deleted using approved data sanitization methods prior to device reuse or disposal.
- Storage media must be wiped in accordance with recognized data destruction standards.
- Devices that cannot be securely sanitized must be physically destroyed.
- Data deletion activities must be documented and approved.
- Disposal vendors must provide certification of destruction where applicable.

5.84 Review & Training Cycle

- Mandatory security training for all staff (with specialized training for technical roles).
- This policy will be reviewed annually, after major incidents or following significant changes in technology, regulatory requirements, or threat landscape.
- Next review: 18 February 2027.

5.9 Clear Desk and Clear Screen Policy

5.91 Document Control Page

Field	Details
Policy Title	Clear Desk and Clear Screen Policy
Policy Number	FTAID-POL-009
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Head of HR
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Physical Controls
ISO 27002:2022 Sub-domain	Clear desk and clear screen, Information Classification, Physical Security Monitoring
ISO 27002:2022 Control	7.7, 7.4, 5.12
Related Policies	Acceptable use of information and other associated assets, Securing offices, rooms, and facilities, Classification of information
Approval Status	Approved

5.92 Purpose and Scope

Purpose

This policy ensures that sensitive information, including Patient Health Information (PHI) and Electronic Health Records (EHR), is protected from unauthorized access by maintaining clear desks and secured screens in all FortisAid facilities.

It supports the confidentiality and integrity of healthcare data in compliance with regulatory and information security requirements.

Scope

This policy applies to all employees, clinicians, contractors, and third-party personnel working within FortisAid offices, clinical environments, and remote work locations.

It covers all physical and digital workspaces where sensitive information is processed, displayed, or stored.

FortisAid Context

As a healthcare organization handling confidential patient data, FortisAid must prevent accidental or intentional disclosure of PHI in shared clinical spaces, reception areas, nursing stations, administrative offices, and remote work environments.

5.93 Policy Statements / Requirements

1. Clear Desk Requirements

- Sensitive documents, including patient files and reports, must not be left unattended on desks.
- All confidential documents must be stored in locked cabinets or secure storage when not in use.
- Printed PHI must be disposed of using approved secure shredding facilities.
- Portable storage devices containing sensitive data must be secured when not in use.

2. Clear Screen Requirements

- Computer screens must be locked when unattended (automatic screen lock after defined inactivity period).
- Users must log out of clinical and administrative systems at the end of each session.
- Privacy screen filters must be used in high-traffic or public-facing areas.

- Remote workers must ensure screens are not visible to unauthorized individuals.

5.94 Review and Revision

This policy will be reviewed annually or following significant security incidents or regulatory updates.

Next scheduled review: 18 February 2027.

6.0 AI Governance Policy

6.11 Document Control Page

Field	Details
Policy Title	AI Governance Policy
Policy Number	FTAID-POL-010
Author	Head of Governance Risk and Compliance
Policy Owner	Chief Information Security Officer
Reviewer	Data Protection Officer
Approver	Chief Executive Officer
Version	1.0
Effective Date	20 February 2026
Current Review Date	20 February 2026
Next Review Date	20 February 2027
ISO 27002:2022 Domain	Organizational Controls
ISO 27002:2022 Sub-domain	Threat Intelligence
ISO 27002:2022 Control	5.17
Related Policies	Data Protection Policy, Third-Party Security Policy, Privileged Account Policy
Approval Status	Approved

6.12 Purpose and Scope

Purpose

To establish governance for AI/ML systems used in clinical data analytics, remote patient monitoring (RPM) predictions, and decision support, ensuring patient safety, data privacy, and regulatory compliance.

Scope

All AI/ML models, algorithms, and tools processing PHI/PII within FortisAid's cloud platforms, EHR integrations, and RPM services.

FortisAid Context

Governs AI analytics on EHR, diagnostic images, lab results, and RPM data streams for healthcare providers.

6.13 Policy Statements / Requirements

1. AI Inventory and Classification

- Maintain central AI inventory documenting all models (RPM predictions, diagnostic analytics, triage tools) with data sources, PHI classification, and risk rating (Low/Medium/High).
- High-risk AI (direct clinical impact: dosing, triage) requires CISO + Clinical Systems Director approval.
- All AI processing special category data (health) triggers mandatory DPIA per UK GDPR Article 35.

2. Threat Intelligence and Model Risk Assessment

- Leverage AI-specific threat intelligence (5.7) for healthcare/cloud risks: bias, poisoning, inversion attacks.
- Conduct pre-deployment risk assessment evaluating data quality, model robustness, bias testing, adversarial robustness.
- Vendor AI services (AWS SageMaker, Azure ML) assessed per 5.23 cloud security requirements.

3. Data Governance and Privacy (5.34)

- PHI minimization: Use pseudonymized/synthetic data for training where possible; raw PHI only with explicit consent.
 - Implement differential privacy or federated learning for RPM data to prevent re-identification.
 - Model cards documenting training data demographics, bias metrics, performance on subgroups published internally.
4. Monitoring and Human Oversight (8.16)
- Deploy model monitoring tracking drift, performance degradation, bias drift on production RPM/clinical data.
 - Human-in-the-loop required for high-risk decisions (triage, dosing recommendations).
 - Incident reporting: AI errors/bias incidents reported per Incident Management

6.14 Review and Revision

- This policy will be reviewed annually or following significant incidents (AI bias events, model failures, regulatory changes).
- Next scheduled review: 20 February 2027.
- Triggers for unscheduled review: MHRA AI guidance updates, new GDPR enforcement, major AI incidents.

FortisAid Policy Compliance Framework

FortisAid Policy Compliance Framework is designed to ensure that all information security policies within FortisAid are regularly reviewed, updated, and monitored to maintain their effectiveness in safeguarding patient data and clinical services. The framework outlines the roles and responsibilities associated with policy reviews, as well as the frequency and process for assessments. It assigns key stakeholders to review, implement, and track policy compliance on an **annual** or **quarterly** basis, ensuring continuous alignment with regulatory requirements and industry best practices. This structured approach guarantees that all security policies are actively maintained, risks are identified and mitigated, and the organization's information security posture remains robust over time.

The following images present the review schedules, responsible roles, and the specific actions required for each policy's implementation and monitoring.

Policy Name	Policy Statement/Guideline	Frequency of Review	Reviewer	Implementer
Information Security Policy	Overarching information security governance, risk-based controls and compliance.	Annual	Data Protection Officer	Head of Governance Risk and Compliance
Information Classification Policy	Classification, labelling and handling of PHI/PII and clinical/operational data.	Annual	Clinical Systems Director	Information Security Manager
Identity Management and Access Control Policy	Identity lifecycle and access control (RBAC, least privilege, JML).	Annual	Security Engineering Lead	IAM Specialist
Privileged Account Policy	Creation, use and review of privileged accounts and admin access.	Annual + Quarterly operational review	Security Operations Lead	Security Engineering Lead
AI Governance Policy	Governance, risk assessment and monitoring of AI/ML systems.	Annual	Data Protection Officer	Head of Governance Risk and Compliance
Incident Management Policy	Detection, response and post-incident improvement for security incidents.	Annual + Quarterly exercises	Clinical Systems Director	Security Operations Lead
Clear Desk and Clear Screen Policy	Physical and screen security to prevent unauthorised access to PHI.	Annual	Head of HR	Information Security Manager
Data Protection and Privacy Policy	Lawful processing and protection of personal and special category data.	Annual	Head of Governance Risk and Compliance	Data Protection Officer
Third-Party and Supplier Security Policy	Vendor risk assessment, contractual controls and ongoing monitoring.	Annual	Information Security Manager	Head of Procurement and Vendor Management
Endpoint and Clinical Device Security Policy	Security of endpoints and clinical devices (hardening, malware, data deletion).	Annual	IAM Specialist	Security Engineering Lead

FortisAid Policy Compliance Framework

January	February	March	April	May	June	July	August	September	October	November	December	Comments/Evidence	Status
												Annual IBM® audit report, risk register, management review minutes, ISO 27002 control mapping	Approved & Active
												Classification register, sample labelled documents, quarterly label audit checklist and findings, DLP/PIEDM export for PHI/PII events.	Approved & Active
												JML (joiner/mover/leaver) logs, quarterly access review reports, privilege change approvals, access recertification evidence.	Approved & Active
												Privileged account inventory, ITT elevation logs, session recordings, quarterly admin access recertification records.	Approved – Quarterly Reviews Planned
												AI inventory register, model cards, DPIAs for high-risk AI, AI Governance Committee minutes, bias and performance audit reports.	Approved & Active
												Incident tickets, incident response playbooks, quarterly tabletop exercise reports, lessons-learned actions log	Approved – Exercises Planned
												Physical inspection checklists, spot-check logs, photos (where appropriate), HR/line manager follow-up actions.	Approved & Active
												DPIAs, ROPA, SAR/DSAR log, breach register, privacy training completion reports.	Approved & Active
												Vendor risk assessment reports, signed BAAs/contracts, vendor security scorecards, high-risk vendor audit findings.	Approved – Audits/Reviews Planned
												Endpoint/EDR dashboards, patch compliance reports, asset inventory, data deletion and device disposal certificates.	Approved & Active

Review Colour Legend	
Green	– The review or control activity is scheduled for that month (e.g. annual review in February, quarterly checks in Mar/Jun/Sep/Dec).
Yellow	– Preparation month immediately before a scheduled quarterly or annual review (e.g. January before a February annual review; February/May/August/November before Mar/Jun/Sep/Dec activities).

FortisAid Policy Compliance Framework Continuation

Uploading and Signing Policies on Wizer

To ensure all employees are aware of and acknowledge the organization's information security policies, FortisAid utilized the **Wizer** platform for policy management and communication. This platform serves as a centralized system for uploading, signing, and tracking policy acknowledgment across the organization. The following steps outline the process:

1. Creating a Wizer Account

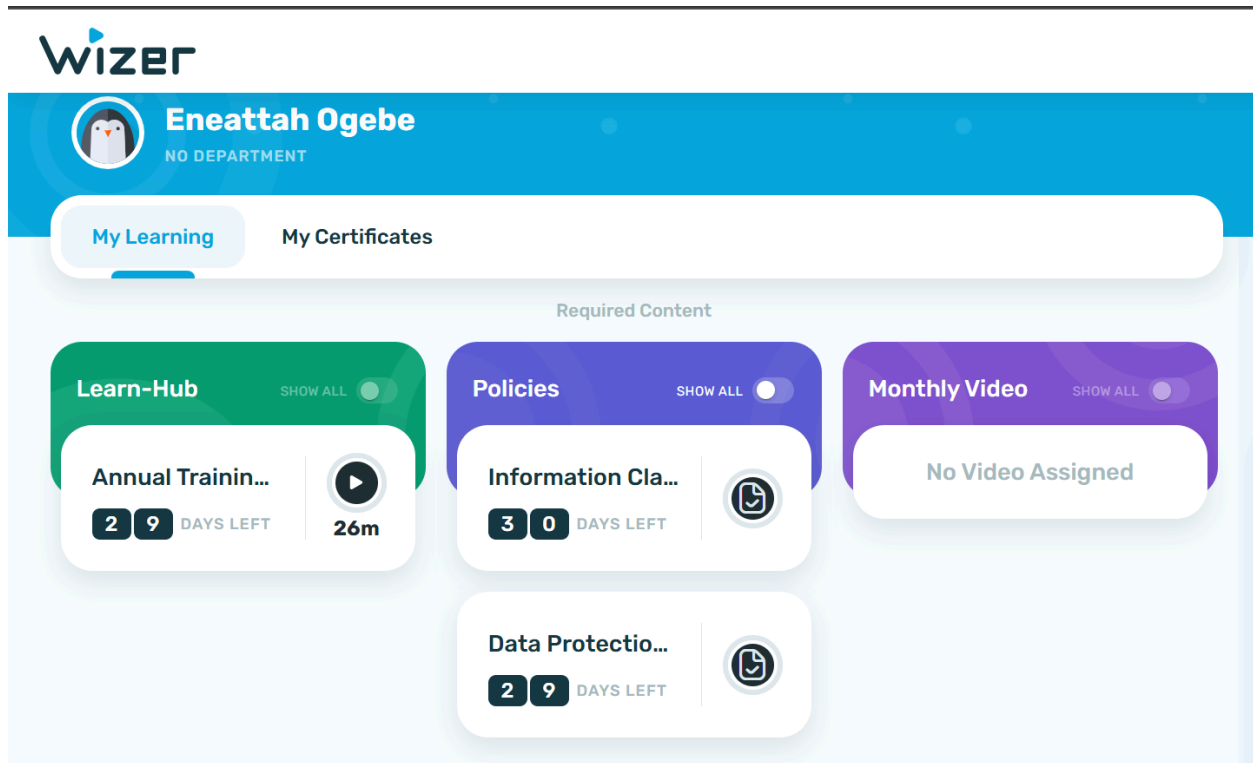
A Wizer account was created to allow for easy upload and distribution of FortisAid's information security policies. The platform facilitates centralized access to all policies, enabling employees to easily access and sign them.

2. Uploading Policies

All policies were uploaded into the Wizer platform as PDF documents. Each policy was added to the platform with an accompanying due date for acknowledgment and a clear call to action for employees to read and sign the document. This ensured that employees were aware of the policies and deadlines for completion.

3. Policy Acknowledgment

Once uploaded, employees were notified via the Wizer dashboard, prompting them to review the policies. Each policy was clearly labeled, and the progress of policy acknowledgment was tracked, ensuring that no employee missed the chance to review or sign the required documents. A screenshot of the Wizer dashboard shows employees receiving clear notifications regarding their required policies and deadlines (see attached screenshot).

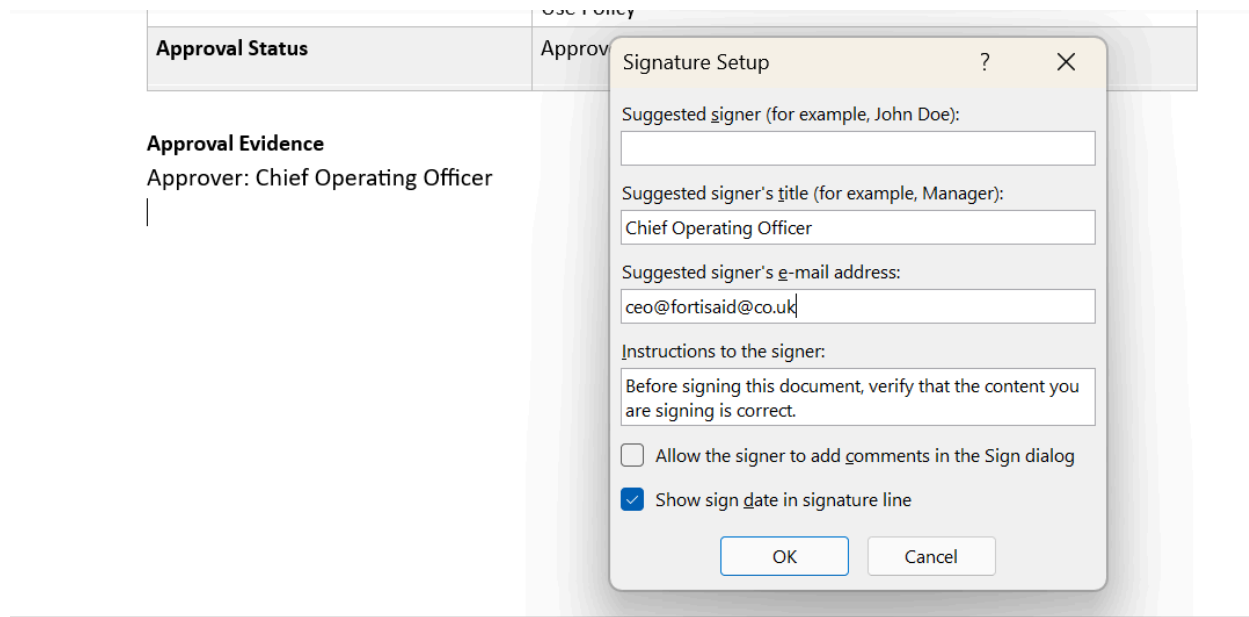


Wizer Learner Dashboard

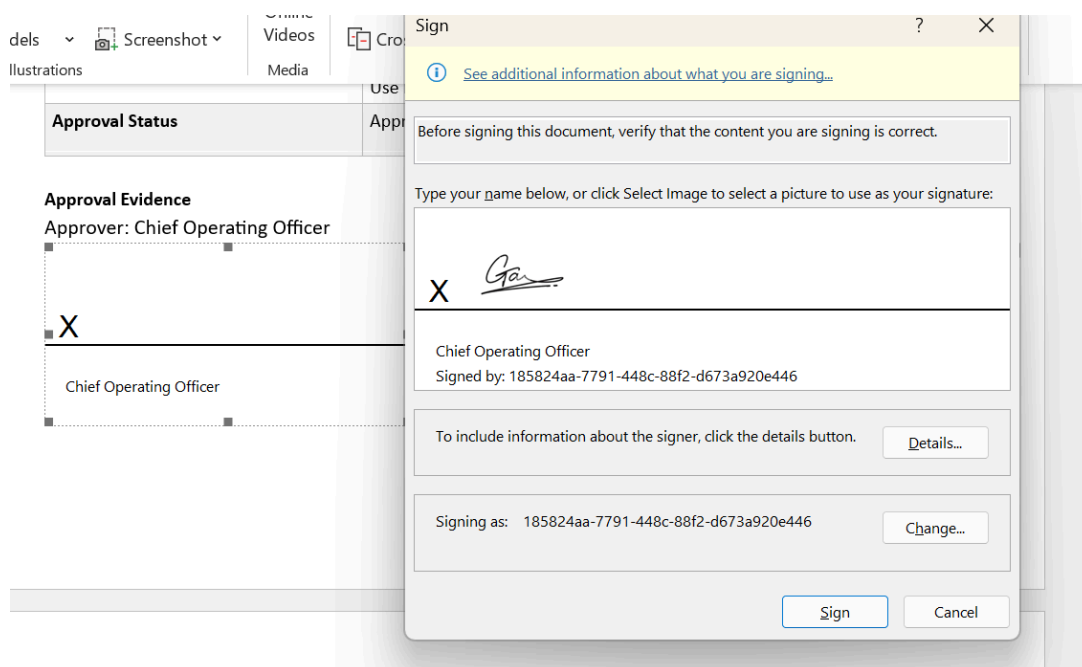
4. Policy Signing Process

The signing process was conducted electronically within the Wizer platform. Employees were prompted to verify the accuracy of the policy content before electronically signing each document.

- As shown in the attached screenshot from the platform, the Chief Operating Officer (COO) signed off on the policies, confirming their approval.
- Wizer allows for digital signatures, providing an audit trail for compliance tracking. This ensures that all policies are approved and acknowledged by the correct individuals, with verifiable timestamps for each signature.



Signature setup for the COO



Signature of the COO

5. Communication of Policies to Employees

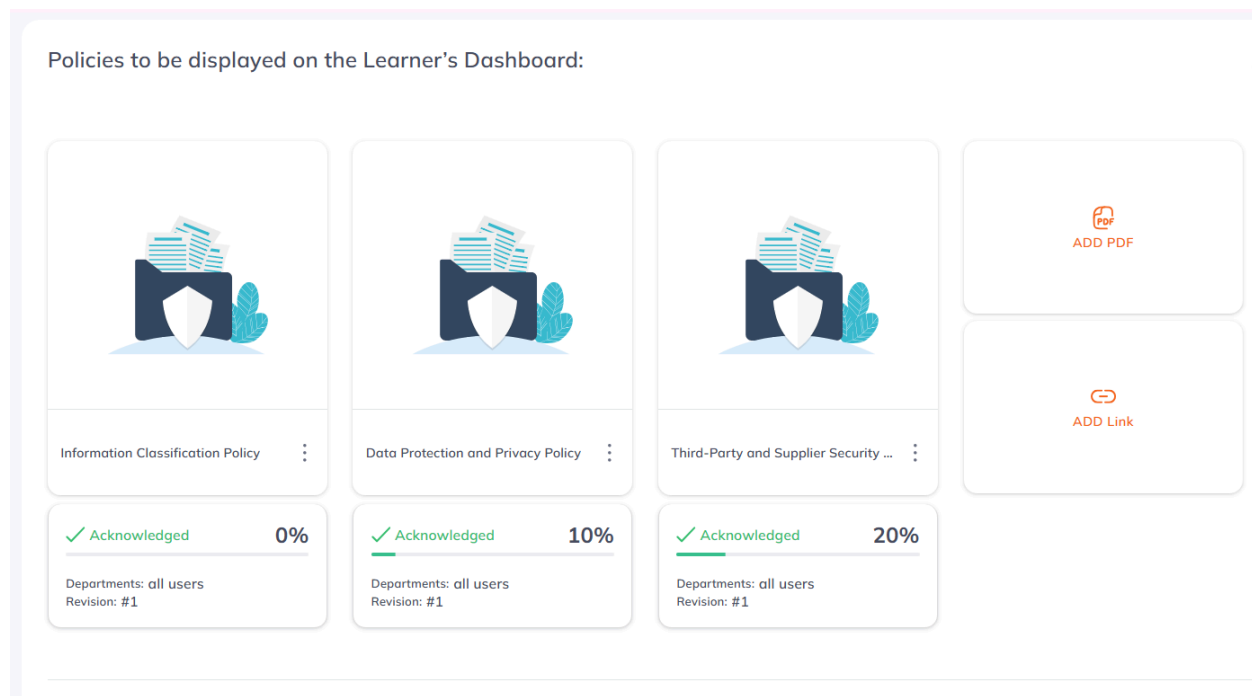
After uploading the policies and ensuring they were signed, the platform allowed for easy communication of policies to all employees. Wizer's notifications and reminders ensured that no employee missed the review and acknowledgment process.

- Each employee was required to acknowledge receipt of the policy, which was then tracked for compliance.
- The platform also offers detailed reporting on who has completed the sign-off process, providing HR and compliance teams with the data they need to ensure full compliance across the organization.

6. Ongoing Monitoring and Reporting

Wizer also provides functionality for tracking policy compliance. As shown in the screenshot of the Wizer platform below, FortisAid can easily monitor the percentage of employees who have acknowledged each policy.

- Compliance reports can be generated to identify employees who have not yet signed the policies, allowing for timely follow-up.



FortisAid Employees Tracking Dashboard

The image below shows the final outlook of a policy when signed.

Information Classification Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-004

Version 1.0 | Effective: 18 Feb 2026

Document Control Page

Field	Details
Policy Title	Information Classification Policy
Policy Number	FTAID-POL-004
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Clinical Systems Director
Approver	Chief Operating Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls
ISO 27002:2022 Sub-domain	Classification of information; Labelling of information; Privacy and protection of PII
ISO 27002:2022 Control	5.12, 5.13, 5.34
Related Policies	Data Protection and Privacy Policy; Access Control Policy; Acceptable Use Policy
Approval Status	Approved

Approval Evidence

Approver: Chief Operating Officer

25/02/2026

X 

Chief Operating Officer

Signed by: 185824aa-7791-448c-88f2-d673a920e446 |

A signed policy

Recommendations for successful implementation of the Framework.

The successful implementation of FortisAid's Policy Compliance Framework is crucial for maintaining a strong security posture and ensuring ongoing regulatory compliance. To effectively enforce and monitor the policies, it is essential to establish clear guidelines and processes that support continuous improvement and accountability. The following recommendations outline key actions that will enhance the organization's ability to implement, monitor, and uphold the policies, ensuring that all stakeholders are properly trained, compliance is effectively monitored, and corrective actions are taken where necessary. By following these recommendations, FortisAid can create a strong culture of security and compliance that aligns with industry best practices and regulatory requirements.

1. **Continuous Training and Awareness Programs:** To ensure all employees and relevant stakeholders understand their roles in information security, mandatory training should be conducted on the developed policies.
 - a. Training content should cover key topics such as data protection, secure access control, and incident reporting.
 - b. Provide role-based training for departments handling sensitive data or high-risk activities.
 - c. Annual refresher courses should be mandatory for all staff to reinforce security best practices.
2. **Automated Monitoring and Tools:** To support real-time monitoring and reduce human error, automated tools (such as SIEM, endpoint protection systems, and access management tools) should be implemented.
 - a. These tools should continuously monitor activities such as user access, endpoint device security, and data transfer compliance.
 - b. The tools should also generate detailed compliance reports and alerts for non-compliance, allowing for timely intervention and corrective actions.
3. **Regular Audits and Reviews**

To maintain compliance and identify areas for improvement, the organization should perform regular internal audits and policy reviews.

 - a. Quarterly audits of sensitive data access, privileged accounts, and vendor security should be conducted.
 - b. Annual policy reviews should be scheduled to ensure alignment with regulatory updates (e.g., GDPR, HIPAA) and evolving organizational needs.

4. Executive Support and Leadership

Successful policy implementation requires top-down support from leadership.

- a. The CEO and CISO should sponsor the policies, ensuring their enforcement at the highest levels.
- b. Leadership must be involved in annual reviews, promoting a culture of security and compliance.

5. Clear Accountability and Ownership

Assign clear roles and responsibilities for monitoring compliance, reporting incidents, and handling non-compliance.

- a. Each policy should have an appointed policy owner (e.g., CISO, DPO), as well as assigned compliance monitors (e.g., IAM Specialist, Security Engineer).
- b. Accountability structures should be established at both the individual and department levels, with KPIs tied to compliance performance.

6. Incident Response and Continuous Improvement

Incident management should be an ongoing priority. Any identified gaps or security incidents must lead to improvements in policies and procedures.

- a. Incident reports should be reviewed not only to identify root causes but also to ensure that security policies are refined based on findings.
- b. An effective feedback loop should be established for post-incident reviews, ensuring that lessons learned inform future training and policy revisions.

7. Vendor and Third-Party Compliance Management

Ensure that third-party vendors comply with FortisAid's security policies, especially those related to data protection and access control.

- a. Regular audits of third-party vendors and contractual agreements must be in place to ensure their compliance.
- b. Vendor performance reviews should be scheduled quarterly to assess the effectiveness of the security measures they have implemented.

8. Policy Integration with Risk Management

Security policies should be directly linked to the organization's Risk Management Framework.

- a. Risk assessments must be conducted regularly, and the findings should influence policy updates.
- b. Ensure that new policies are tested in the context of FortisAid's enterprise risk landscape before final approval.

Conclusion

In conclusion, the development and implementation of FortisAid's security policies are essential for safeguarding sensitive data and ensuring compliance with industry standards and regulations. By aligning the policies with the ISO/IEC 27002:2022 framework and incorporating best practices for risk management, FortisAid is better equipped to address emerging security threats and regulatory challenges. The Policy Compliance Framework, supported by the outlined recommendations, ensures that the policies will be effectively monitored, enforced, and continuously improved. Ultimately, these efforts will strengthen FortisAid's overall security posture, protect patient data, and foster trust with patients, partners, and regulatory bodies.

References

- International Organization for Standardization. (2022). *ISO/IEC 27002:2022 Information security controls*. <https://www.iso.org/standard/73906.html>
- U.S. Department of Health & Human Services. (1996). *Health Insurance Portability and Accountability Act (HIPAA)*. <https://www.hhs.gov/hipaa/for-professionals/index.html>
- NHS England and NHS Improvement. (2022, April). *Data Protection Policy*. <https://www.england.nhs.uk/long-read/data-protection-policy/>
- NHS Digital. (2022, April). *Information governance and security policy v2.0*. <https://nottcs.icb.nhs.uk/wp-content/uploads/sites/20/2022/04/IG-003-Information-Governance-Security-Policy-Final.pdf>